

Structuring principles and anchoring activity

Principles that decide in advance, and that is their job

Session objectives

By the end of this tutorial:

- **Define** the three structuring principles of security architecture: defense in depth, least privilege, network isolation
- **Recognize** their violation in a real situation, before the incident that would make it obvious
- **Assess** an information security maturity level with a simple grid, and use it to prioritize without offending anyone
- **Connect** these technical principles to the morning's governance decisions: a principle is a decision made once and for all

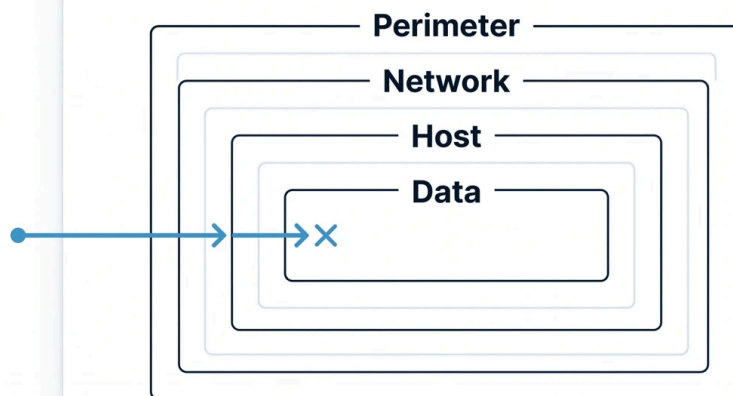
Prerequisites

- This morning's lecture: the three decision levels, the RACI matrix, the arbitration of the inter-subsidiary running thread. The principles of this tutorial are the tooling of the tactical level: what the subsidiaries apply once governance has spoken.
- The CISO's briefing: the three files, two of which will find their technical dimension again here.

The presentation that arms the exercises: three principles and a grid

A quarter of an hour of vocabulary, and a point of honesty before starting: the first two principles below are established assets of the profession, present in every security doctrine; the definitions that follow are the module's, phrased to be usable in exercises.

Defense in depth, first. The problem it addresses is as old as fortified castles: any single defense eventually gives way, and an organization that stakes everything on one barrier, the perimeter firewall, the antivirus, the password, discovers on the day of the incident that behind that barrier, everything was open. Defense in depth is the principle of layering several independent lines of defense, so that the fall of one does not open the whole: the attacker who crosses the perimeter meets segmentation, then authentication, then detection, then the encryption of the data itself. The decisive word is "independent": two barriers that fall for the same cause, two systems protected by the same administrator account for example, form only one line disguised as two. And its limit, which a CISO must know how to state to management: depth costs, in money and in ease of use; it is a principle dosed according to the value of what it protects, not an incantation.



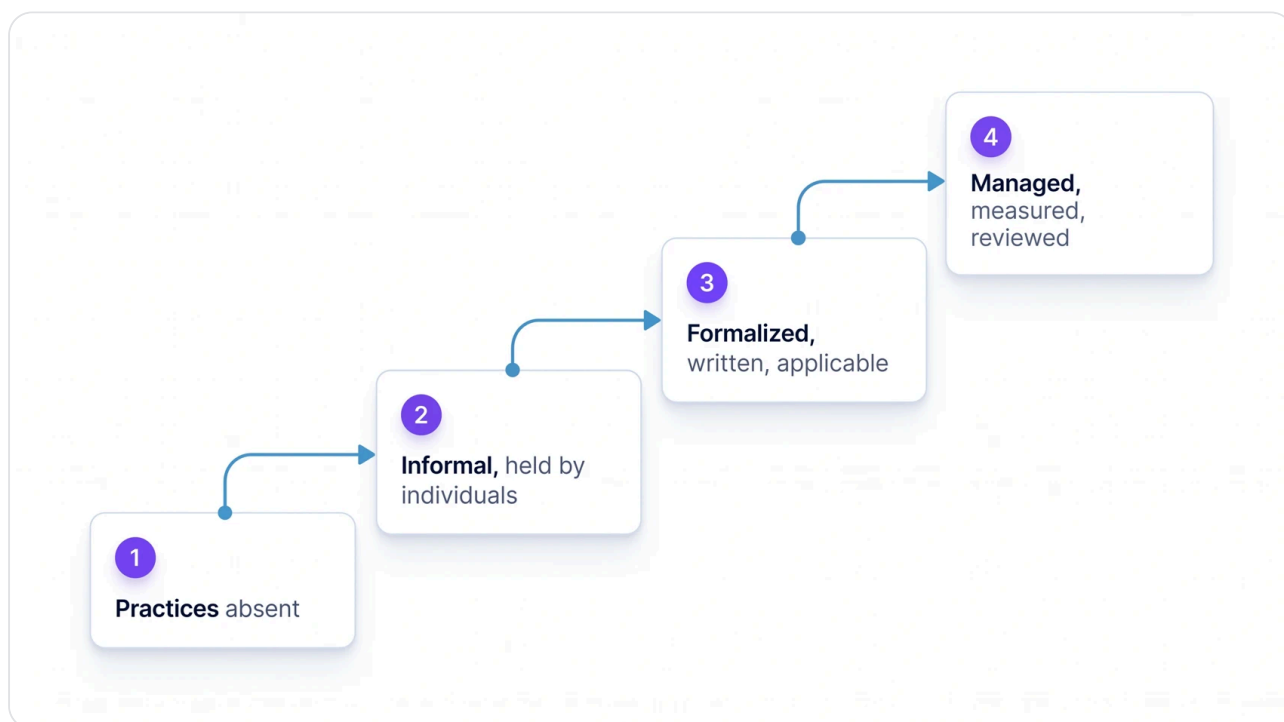
One barrier gives way, the next ones hold

One barrier gives way, the next ones hold.

The principle of least privilege, next. The problem: access rights only ever grow; they are granted to fix something, never taken back, and three years later a service provider's account opens half the information system. ANSSI's IT hygiene guide describes the phenomenon in the field's own words: « l'affectation de comptes disposant de trop nombreux privilèges par rapport à la tâche à réaliser, l'utilisation de comptes personnels pour exécuter des services ou tâches périodiques, ou encore le choix de mots de passe peu robustes donnant accès à des comptes privilégiés » ("the assignment of accounts holding far too many privileges relative to the task at hand, the use of personal accounts to run services or periodic tasks, or the choice of weak passwords giving access to privileged accounts"). The principle of least privilege consists of granting each user, account or process only the rights strictly necessary for its task, and nothing more. Its mechanics are less technical than they appear: it requires KNOWING what is necessary, hence defining the tasks, hence reviewing the rights regularly, which makes it first and foremost a governance discipline. Its mirror-image limit: applied without discernment, it multiplies access requests and pushes teams toward workarounds; badly dosed least privilege manufactures tomorrow's shadow IT.

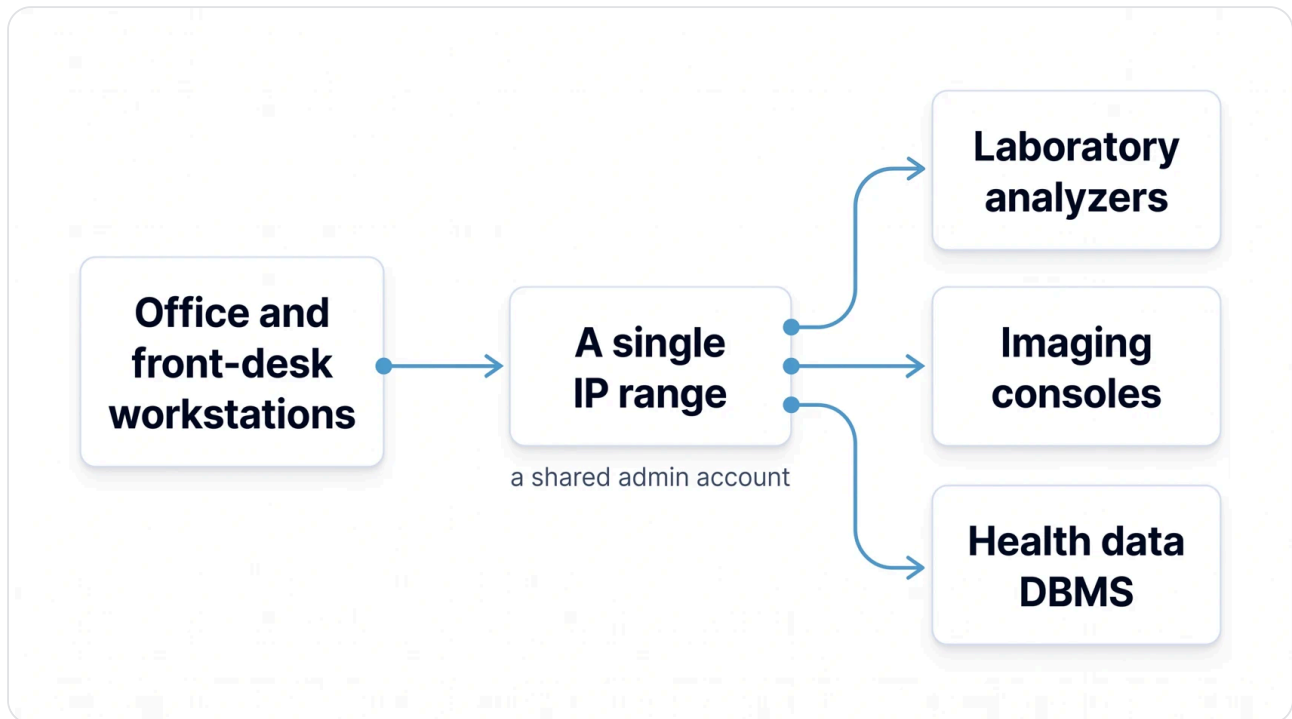
Network isolation, finally, and this one has an official source worth knowing, because it accompanies any regulatory career. For essential information systems, the SIE of the French regulatory framework, ANSSI recommends: « L'opérateur doit segmenter son SI en plusieurs systèmes et sous-systèmes. Les SIE doivent être cloisonnés des autres SI de l'opérateur et des SI tiers. Chaque SIE doit être subdivisé en sous-systèmes rassemblant des ressources assurant des fonctionnalités similaires et ayant des niveaux de sensibilité, d'exposition et de sécurité homogènes. » ("The operator must segment its information system into several systems and subsystems. The SIE must be partitioned from the operator's other information systems and from third-party systems. Each SIE must be subdivided into subsystems grouping resources that provide similar functions and have homogeneous levels of sensitivity, exposure and security.") The logic matters more than the letter: what is alike is grouped, sensitivity, exposure, function, and the rest is separated, so that a compromise remains a local event. Isolation is the network translation of defense in depth, and its typical failure has a vivid name: the "flat" network, where everything sees everything, and where the first compromised workstation hands over the entire group. The principle's limit: absolute isolation does not exist, business lines need flows; isolating is therefore above all CHOOSING one's passages and controlling them, exactly what the running thread's arbitration did this morning with its dedicated VLAN and its inspection firewall.

There remains the measuring tool: **information security maturity**. The problem: between "all is well" and "everything must be redone", a scale is needed, otherwise every priority discussion turns into opinion. Information security maturity assesses not the presence of tools but the degree to which practices are organized, and the module uses a deliberately simple four-level grid: 1, practices absent; 2, informal practices, resting on individuals; 3, formalized practices, written and applicable; 4, managed practices, measured and reviewed. Its main virtue is diplomatic as much as analytical: telling a subsidiary "you are at level 2, practices exist but rest on individuals" opens a discussion about progress; saying "this is amateurish" opens a war. Its limit: such a simple grid does not replace an audit, it prepares the audit's prioritization, and the healthcare sector learned from 2019, the year the Rouen university hospital (CHU de Rouen) was one of three organizations, along with Groupe M6 and Fleury Michon, to later testify in ANSSI's ransomware guide, that the maturity level is paid for dearly when discovered during the crisis.



The module's grid: four levels, from absent practices to managed ones.

The three principles are remembered as three questions put to any architecture: if this barrier falls, what is behind it? Does this account have more rights than its task? And if this machine is compromised, how far can it see? Three questions, thirty seconds, and the pre-diagnosis is made.



The findings passed on by the Santé subsidiary.

Exercise 1: MERIDIAN Santé, imaging on everybody's network

The inventory passed on by the Santé subsidiary contains two findings that put the three questions to work: the facilities' laboratory analyzers and imaging consoles are connected on the same IP range as office computing, and an identical local administrator account is deployed across the entire fleet.

1. **Identify** the principle or principles violated by each of the two findings, justifying with one sentence per principle (hint: the second finding violates two at once, one of them subtly).

2. **Describe** the scenario this combination makes possible, in three steps at most, from the compromised office workstation to the care equipment.

3. **Formulate** the recommendation in governance language: which decision, at which level (strategic, tactical, operational), and who should be A in the corresponding RACI?

Suggested time: 12 minutes.

Exercise 2: MERIDIAN Logistique, the provider who holds the keys to the domain

Two findings on the Logistique side: the business IT networks and the warehouse equipment (OT) networks are interconnected without segmentation; and the equipment's Third-Party Maintenance Provider shares a domain administrator account with the subsidiary's System Administrator.

1. **Analyze** the account sharing in light of least privilege: draw up the list of everything this finding makes impossible (hint: think of traceability, revocation, accountability, not just the risk of intrusion).

2. **Explain** why the IT/OT interconnection specifically aggravates this finding, drawing on network isolation.

3. **Propose** the remediation sequence in the right order: what to start with, and why that order (hint: one of the two findings amplifies the other).

Suggested time: 12 minutes.

Exercise 3: the Éducation & Territoires division, arbitrating a project with principles

The Éducation subsidiary is carrying a learning platform project that must connect to the administrative databases of the Territoires subsidiary. The Territoires IS Manager objects: those databases serve some thirty client local authorities and contain regulated citizen data. The project goes up to the Group CISO for arbitration.

1. **Examine** the case with the three principles: what does each say about this project, in one sentence per principle?

2. **Arbitrate** using the structure of the morning's running thread: formulate a decision that authorizes UNDER CONDITIONS, specifying the guarantees required, and write it in three sentences at most.

3. **Rate** finally the information security maturity of the four subsidiaries on the module's grid, based on the findings recalled below and on what the day has taught about them, with one sentence of justification per subsidiary. This is the session's anchoring activity: this grid will serve as the starting point for the entire module.

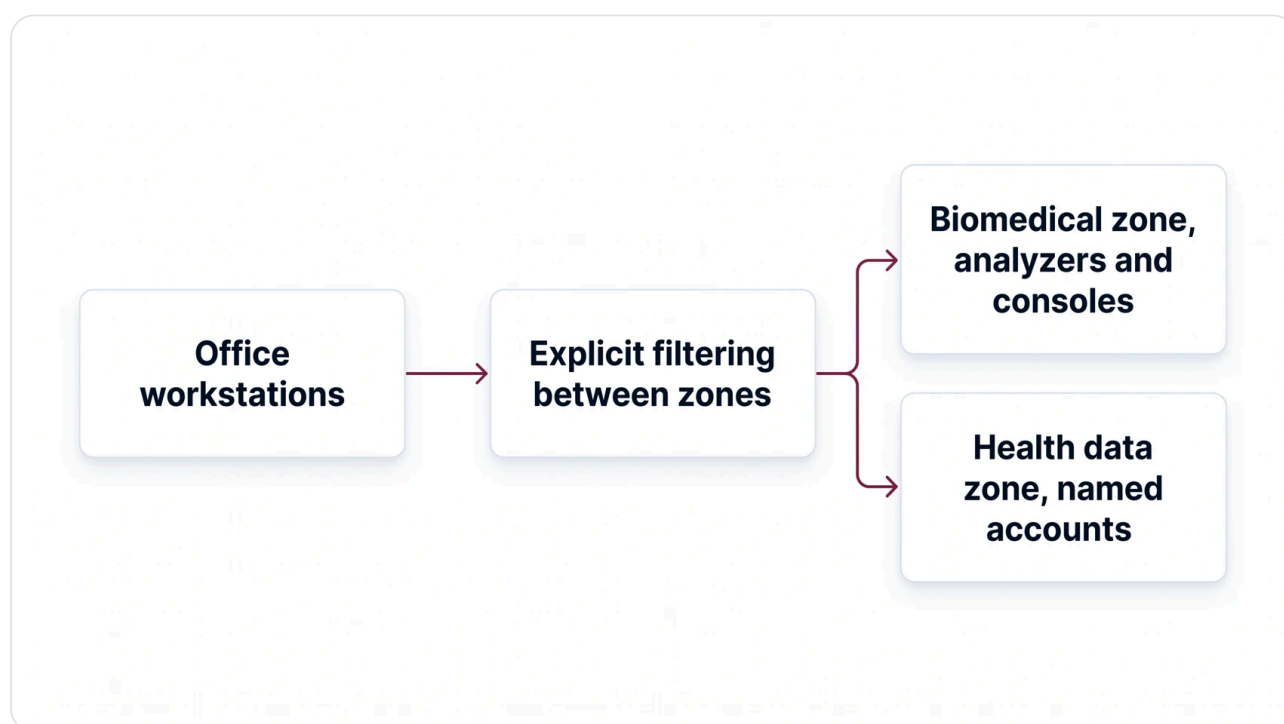
The case findings, subsidiary by subsidiary, so that the rating rests on facts and not on an impression. Santé: laboratory analyzers and imaging consoles on the office IP range, with a common administrator account, and business applications using local passwords without multi-factor authentication. Logistique: office and industrial networks interconnected, and a domain account shared with the third-party maintenance provider. Éducation: administrator accounts shared between the teams of the division with the pooled IT department, in a context of limited resources. Territoires: logs kept locally, without centralization toward the group SOC, even though the regulatory requirements are known and written into the delegation contracts.

Suggested time: 15 minutes.

Answer keys and assessment criteria

Answer key for exercise 1

First finding: network isolation is violated head-on, care equipment, sensitive and hard to update, shares the IP range of office computing, the population most exposed to phishing; heterogeneous sensitivities and exposures in the same segment, exactly what the recommendation quoted in the presentation proscribes. Second finding: least privilege first, an identical administrator account across the entire fleet gives whoever obtains it rights out of all proportion to any task; and, more subtly, defense in depth, because this single account turns all the fleet's barriers into ONE line, the one that falls when the account leaks; two defenses that give way for the same cause are only one. The three-step scenario: an office workstation is compromised by phishing; the attacker retrieves the local administrator account there, the same one everywhere; the attacker moves laterally to the analyzers and consoles, on the same network, with administrator rights. The governance recommendation: a tactical decision by the subsidiary, segment the biomedical equipment and deploy unique administrator accounts, but backed by a group-level directive, and in the RACI, the Group CISO as A on security maintenance, the subsidiary's IT department as R, in line with the morning's grid.



The target the principles impose.

Answer key for exercise 2

What the shared account makes impossible: attributing an action to a person, traceability dies with sharing; revoking the provider without breaking internal administration, since it is the same account; bounding liability contractually, since no one can prove who did what; and applying the slightest privilege review, a shared account being by construction oversized for each of its uses. The IT/OT interconnection aggravates all of this through reach: without segmentation, rights stolen on the business side carry all the way to the warehouse equipment, and the absent isolation converts an account problem into a factory problem. The expected remediation order: the accounts first, separating provider and administrator, tracing, revoking, because it is fast, contractual, and immediately reduces the attack surface; then the IT/OT segmentation, a longer project; the reverse order would leave an all-powerful account circulating for months on an already segmented network, that is, a master key in a building with new doors. Accept the opposite argument if it is defended: what matters is having reasoned about the amplification.

Answer key for exercise 3

The examination through the principles: least privilege requires that the platform access only the strictly necessary data from Territoires' databases, not their entirety; isolation forbids a direct connection between a service exposed to the student public and regulated citizen databases; defense in depth demands that several independent barriers live between the two. The expected arbitration, on the running thread's model: the project is authorized, BECAUSE access will pass through a demilitarized zone (DMZ) and secured APIs exposing only the necessary data, with the authentication and logging guarantees required by the group; the Territoires IS Manager gets the protections, Éducation gets its project, the group gains one more piece of case law. For the maturity grid, a defensible rating in light of the day: Santé 2, practices exist but the biomedical equipment and the accounts betray the absence of formalization; Logistique 2, operations hold but rest on individuals and shared accounts; Éducation 2 leaning toward 1 on access management, administrator accounts shared in a context of limited resources; Territoires 2, regulatory requirements known but logs kept locally, without centralization. The essential point is not the exact score: it is that no subsidiary is rated without justification, and that the grid produces a priority that can be debated in committee rather than a league table.

Assessment criteria

CRITERION	INSUFFICIENT	EXPECTED	EXCELLENT
Principles identified	Recited without any link to the findings	Each finding attached to the right principles, justified	The shared account's double violation seen, including the "single line" effect
Attack scenario	Vague catastrophizing	Three plausible steps, from workstation to equipment	Same, with each step linked to the principle that would have blocked it
Governance language	Purely technical recommendations	Decision, level, and RACI A named	Same, with the group directive distinguished from its subsidiary application
Arbitration (ex. 3)	Flat prohibition or flat authorization	Authorization under conditions, guarantees specified	Same, structured like the running thread: nobody wins, the group gains a rule
Maturity grid	Scores without justification	Four ratings each justified in one sentence	Same, with the diplomatic use of the grid articulated